

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:
TS. Bùi Văn Hiếu
TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) luôn bị quá tải bởi số lượng cảnh báo khổng lồ, dẫn đến hội chứng "bội thực cảnh báo" và nguy cơ bỏ sót các Cuộc tấn công có chủ đích (APT) nghiêm trọng. Để giải quyết những hạn chế cố hữu của các hệ thống dựa trên luật tính truyền thống và nút thắt về độ trễ khi xử lý trực tiếp log mạng qua Mô hình Ngôn ngữ Lớn (LLM), luận văn này giới thiệu SENTINEL: Kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Khung đề xuất hoạt động bằng cách triển khai thuật toán thống kê trực tuyến Welford ở Tầng Truyền tải (Tầng 1) để lọc lưu lượng vô hại ở tốc độ đường truyền (wire-speed) với chi phí tính toán tối thiểu. Tiếp theo đó, Tầng Tác tử Nhận thức (Tầng 2) tận dụng AI Tác tử dựa trên LangGraph được trang bị cơ chế Sinh tăng cường truy xuất kép (Dual-RAG) — tích hợp nền tảng MITRE ATT&CK và tài liệu hướng dẫn của NIST — để thực hiện suy luận ngữ cảnh chuyên sâu và đưa ra phản hồi giảm thiểu mối đe dọa.

Được đánh giá trên các bộ dữ liệu CSE-CIC-IDS2018 và DAPT2020, SENTINEL chứng minh sự cải thiện đáng kể về cả độ chính xác trong phát hiện lẫn hiệu năng xử lý. Hơn nữa, hệ thống còn tích hợp các cơ chế bảo mật AI mạnh mẽ, bao gồm Đóng gói Dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi log HMAC, đạt tỷ lệ giảm thiểu gần như hoàn hảo đối với các cuộc tấn công thao túng AI đối kháng đã biết và đảm bảo tính toàn vẹn của dữ liệu pháp y. Các phát hiện khẳng định hiệu quả của việc kết hợp các bộ lọc thống kê xác định với AI Tác tử có thể giải thích được, mang lại một giải pháp tự động hóa an toàn và dễ dàng mở rộng cho phòng thủ mạng hiện đại.

Lời cảm ơn

Tôi xin gửi lời biết ơn chân thành và sâu sắc nhất tới hai vị giảng viên hướng dẫn của tôi, TS. Bùi Văn Hiếu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những phản hồi chuyên môn sắc bén cùng sự tận tâm và kiên nhẫn chỉ dạy của các thầy trong suốt chặng đường thực hiện đề tài chính là bệ đỡ vững chắc giúp tôi hoàn thành nghiên cứu này một cách trọn vẹn nhất.

Tôi cũng xin bày tỏ lòng biết ơn sâu sắc tới các giảng viên và cán bộ nhân viên tại Trường Đại học FPT, đặc biệt là Ban đào tạo chương trình Thạc sĩ Kỹ thuật Phần mềm (MSE), những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu, tạo dựng một môi trường nghiên cứu chuyên nghiệp, hiện đại và hỗ trợ tối đa mọi điều kiện thuận lợi cho học viên trong suốt quá trình học tập.

Đồng thời, tôi xin gửi lời cảm ơn tới Ban lãnh đạo và các đồng nghiệp tại FPT Software, nơi tôi đang công tác. Sự tạo điều kiện về mặt thời gian, môi trường làm việc thực tế và những chia sẻ chuyên môn từ các đồng nghiệp đã giúp tôi có thêm nhiều động lực để hoàn thành tốt cả công việc tại cơ quan lẫn nhiệm vụ học tập nghiên cứu.

Cuối cùng và quan trọng nhất, tôi xin dành lời tri ân đặc biệt tới gia đình yêu thương của mình, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, thấu hiểu và động viên tinh thần không ngừng nghỉ của gia đình trong những khoảng thời gian tôi bận rộn với các đợt thực nghiệm kéo dài chính là điểm tựa lớn nhất giúp tôi vững bước trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

Hình 1.	Nút thất nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý.	14
Hình 2.	Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM).	16
Hình 3.	Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM.	18

Danh sách bảng

Bảng 1.	Tóm tắt các Lỗi hỏng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL.	19
---------	--	----

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
C2	Command and Control (Chỉ huy và điều khiển)
CIDR	Classless Inter-Domain Routing (Định tuyến liên miền không phân lớp)
CNN	Convolutional Neural Network (Mạng nơ-ron tích chập)
CVE	Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)
CTI	Cyber Threat Intelligence (Tinh báo mối đe dọa mạng)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
DDoS	Distributed Denial of Service (Từ chối dịch vụ phân tán)
DL	Deep Learning (Học sâu)
DoS	Denial of Service (Từ chối dịch vụ)
EDR	Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GenAI	Generative Artificial Intelligence (Trí tuệ nhân tạo tạo sinh)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IPS	Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
LSTM	Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)
MAS	Multi-Agent System (Hệ thống đa tác tử)
ML	Machine Learning (Học máy)
NGFW	Next-Generation Firewall (Tường lửa thế hệ tiếp theo)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RBA	Runbook Automation (Tự động hóa kịch bản chạy)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SCA	Software Composition Analysis (Phân tích thành phần phần mềm)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
SVM	Support Vector Machine (Máy vector hỗ trợ)
TDIR	Threat Detection and Incident Response (Phát hiện đe dọa và phản hồi sự cố)
TTL	Time to Live (Thời gian tồn tại)
VRAM	Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)
WAF	Web Application Firewall (Tường lửa ứng dụng web)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	5
1 Giới thiệu	8
1.1 Bối cảnh và Động lực nghiên cứu	8
1.2 Mục tiêu Nghiên cứu	9
1.3 Câu hỏi Nghiên cứu	10
1.4 Đối tượng và Phạm vi Nghiên cứu	10
1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu	11
1.6 Các Công trình Liên quan (Related Works)	11
1.7 Đóng góp của Luận văn	12
1.8 Cấu trúc của Luận văn	12
1.9 Tóm tắt chương	12
2 Cơ sở Lý thuyết	13
2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức	13
2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa . . .	15
2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái	15
2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lai	16
2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection	17
2.6 Thuật toán Thống kê Trực tuyến Welford	19
2.7 Tóm tắt chương	20
3 Kiến trúc SENTINEL Đề xuất	21
3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng	21
3.2 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford) .	21
3.3 Tầng 2: Tác tử AI Nhận thức LangGraph	22
3.4 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa	22
3.5 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT	22
3.6 Tầng Rào chắn Bảo mật AI (Guardrails)	23
3.7 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC	23
4 Triển khai Kỹ thuật	24
4.1 Công nghệ Lỗi và Cấu trúc Mã nguồn	24
4.2 Triển khai Tầng 1: Bộ lọc Thống kê RuleEngine và Welford	24
4.3 Triển khai Tầng 2: AI Tác tử và Hệ RAG	25
4.4 Triển khai Tầng Rào chắn AI và Chuỗi HMAC	25

4.5	Triển khai Bảng Điều khiển Quản trị SOC (Streamlit UI)	25
4.6	Đóng gói Docker và Triển khai Hạ tầng	26
5	Thực nghiệm và Đánh giá	27
5.1	Môi trường Thực nghiệm và Bộ Dữ liệu	27
5.2	Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study) . .	27
5.3	Đánh giá Độ chính xác và Kiểm định Thống kê McNemar	28
5.4	Đánh giá Độ trễ Hiệu suất và Kiểm định Mann-Whitney U	28
5.5	Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)	29
5.6	Đánh giá Toàn vẹn Dữ liệu và Chất lượng RAG qua mô hình LLM Trọng tài	29
6	Kết luận và Hướng phát triển	30
6.1	Tổng hợp Kết quả Nghiên cứu Đạt được	30
6.2	Đóng góp Khoa học và Thực tiễn	30
6.3	Các Giới hạn Hiện tại	31
6.4	Hướng Phát triển Tương lai	31
	Tài liệu tham khảo	33

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng được thiết kế để tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh mạng (SOC) hiện đại. Bằng việc phân tích các thách thức hệ thống như nạn bội thực cảnh báo, sự mù lòa của hệ thống dựa trên luật xác định và các giới hạn về tài nguyên tính toán của Mô hình Ngôn ngữ Lớn (LLM), nghiên cứu này trình bày chi tiết thiết kế và xác thực kiến trúc phát hiện lai bảo mật. Chương này phác họa các mục tiêu nghiên cứu, câu hỏi cốt lõi, phạm vi nghiên cứu và phương pháp kỹ thuật thực nghiệm định lượng được áp dụng để chứng minh tính hiệu quả của hệ thống đề xuất.

1.1 Bối cảnh và Động lực nghiên cứu

Mạng doanh nghiệp hiện đại đã chuyển đổi thành các môi trường đám mây không đồng nhất và có vành đai mở rộng, làm tăng đáng kể bề mặt tấn công tiềm ẩn. Sự gia tăng của các môi trường mạng phân tán toàn cầu đã chứng kiến sự dịch chuyển trong chiến thuật của kẻ tấn công từ các chữ ký phần mềm độc hại cô lập sang các chiến dịch Đe dọa Thường trực Nâng cao (APT) lén lút và đa giai đoạn [1], vốn đòi hỏi khả năng phân tích ngữ cảnh liên tục để phát hiện. Những tác nhân đe dọa tinh vi này tận dụng tải trọng đa hình và các kênh chỉ huy điều khiển (C2) để duy trì sự hiện diện lâu dài trong hệ thống.

Để giám sát và giảm thiểu sự cố mạng phát sinh từ các tác nhân trên, các Trung tâm Điều hành An ninh (SOC) hiện đại tiến hành tập hợp nhật ký hoạt động từ NGFW, IDS/IPS và EDR. Thông thường, quy trình phản hồi sự cố tiêu chuẩn sẽ hợp nhất các nguồn nhật ký này về hệ thống Quản lý Thông tin và Sự kiện An ninh (SIEM) trung tâm [2] nhằm mục đích chuẩn hóa dữ liệu và đối sánh tương quan. Tuy nhiên, khối lượng và tốc độ của dữ liệu nhật ký thu nạp khổng lồ đã dẫn đến một "Nghịch lý Dữ liệu Lớn" trong an ninh mạng [3], gây quá tải và làm chậm tốc độ ứng phó sự cố khẩn cấp.

Sự quá tải dữ liệu log này trực tiếp gây ra hội chứng bội thực cảnh báo nghiêm trọng. Các hoạt động giám sát tại SOC thường bị tê liệt khi các chuyên viên phân tích bị ngập chìm

trong hàng ngàn cảnh báo dung lượng lớn nhưng chất lượng thấp, vốn phần lớn là các cảnh báo dương tính giả được sinh ra do nhiễu nền hoặc cấu hình sai của hệ thống [5]. Sự quá tải nhận thức này làm tăng đáng kể nguy cơ bỏ sót các chỉ báo xâm nhập thực sự nguy hiểm.

Thêm vào đó, các hệ thống phát hiện xâm nhập truyền thống vẫn phụ thuộc chặt chẽ vào cơ sở dữ liệu chữ ký tĩnh và các bộ quy tắc thủ công [10], khiến chúng mất đi khả năng nhận biết trước các biến thể đe dọa mới. Dù có hiệu quả với các mối đe dọa đã biết, chúng hoàn toàn mù lòa trước các lỗ hổng Zero-day hoặc mã độc đa hình vốn dễ dàng vượt qua các luật tĩnh bằng những thay đổi tải trọng cực nhỏ.

Để tiết kiệm chi phí lưu trữ nhật ký mạng và tài nguyên xử lý, nhiều SOC thực hiện lấy mẫu ngẫu nhiên hoặc cắt xén dữ liệu log một cách thụ động. Tuy nhiên, các kỹ thuật giảm thiểu dữ liệu thô thiển này gây tổn hại nghiêm trọng đến việc điều tra số do làm đứt gãy chuỗi bằng chứng thời gian cần thiết để liên kết và tái dựng hành vi "chậm và ẩn nấp" của các chiến dịch APT vốn diễn ra lén lút trong nhiều tuần hoặc nhiều tháng [4], khiến các hoạt động di chuyển ngang dài hạn trở nên hoàn toàn vô hình.

Mặc dù các Mô hình Ngôn ngữ Lớn (LLM) có thể tự động hóa quy trình phân loại bằng cách tóm tắt log và lập kế hoạch ứng phó sự cố, việc tích hợp trực tiếp chúng vào SOC gặp phải một nghịch lý tích hợp chứa hai nút thắt lớn đan xen. Thứ nhất, việc suy luận trực tiếp các dòng log mạng thô qua LLM hàng tỷ tham số là bất khả thi về mặt hiệu năng do cơ chế tự chú ý (self-attention) của Transformer có độ phức tạp tính toán lớn gây ra độ trễ cao. Thứ hai, tích hợp trực tiếp giao diện ngôn ngữ tự nhiên làm lộ diện hệ thống trước các rủi ro bảo mật AI đối kháng, tiêu biểu là các cuộc tấn công tiêm prompt từ log (log-substrate prompt injection) nơi kẻ tấn công lợi dụng việc mờ nhạt ranh giới giữa lệnh điều khiển và dữ liệu thô trong LLM [9]. Chỉ dẫn độc hại nhúng trong các trường log (như User-Agent) có thể chiếm quyền điều khiển suy luận của LLM nếu không có cơ chế cô lập nghiêm ngặt. Để giải quyết các nút thắt này, hệ thống SENTINEL đề xuất kiến trúc hai tầng: Tầng 1 lọc dữ liệu không trạng thái ở tốc độ đường truyền, và Tầng 2 thực thi suy luận AI Tác tử được cô lập bảo mật.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát của nghiên cứu này là thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL, kết hợp giữa bộ lọc bất thường thông kê trễ thấp và quy trình suy luận AI Tác tử có trạng thái được bảo vệ an toàn.

Để thực hiện mục tiêu trên, nghiên cứu tập trung giải quyết ba mục tiêu cụ thể. Mục tiêu thứ nhất là triển khai thuật toán thống kê trực tuyến Welford với độ phức tạp $O(1)$ để tính toán phương sai cuộn và Z-Score nhằm lọc lưu lượng mạng vô hại ở tốc độ đường truyền. Mục tiêu thứ hai là thiết kế tác tử tự trị có trạng thái bằng LangGraph và LLM lượng tử hóa cục

bộ, tích hợp các rào chắn bảo mật đầu vào-đầu ra nhằm phân tích an toàn các cảnh báo bất thường và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM. Cuối cùng, mục tiêu thứ ba là xây dựng hệ thống truy xuất kiến thức kép (Dual-RAG) tích hợp MITRE ATT&CK và NIST SP 800-61r2 nhằm làm nền tảng tri thức cho quyết định của tác tử và giảm thiểu ảo giác.

1.3 Câu hỏi Nghiên cứu

Để kiểm chứng khoa học cho kiến trúc đề xuất, nghiên cứu này tập trung giải quyết ba câu hỏi nghiên cứu cốt lõi. Thứ nhất, RQ1 đặt câu hỏi làm thế nào để thiết kế toán học một cơ chế lọc lưu lượng mạng thời gian thực dựa trên baseline thống kê trực tuyến hoạt động ở tốc độ đường truyền nhằm loại bỏ cảnh báo nhiễu nhưng vẫn bảo toàn chuỗi sự kiện của APT. Thứ hai, RQ2 tìm kiếm phương pháp kiến trúc nào có thể tích hợp LLM cục bộ vào quy trình phản hồi sự cố tự động kết hợp đóng gói dữ liệu an toàn để loại bỏ độ trễ và ngăn ngừa các vector tấn công đối kháng nhắm vào hệ thống khi tích hợp LLM. Thứ ba, RQ3 đánh giá hiệu quả thực nghiệm của việc tăng cường bộ nhớ tác tử bằng hệ thống truy xuất tri thức kép sử dụng thuật toán Reciprocal Rank Fusion trong việc tối ưu hóa độ chính xác và giảm thiểu ảo giác của LLM.

1.4 Đối tượng và Phạm vi Nghiên cứu

Đối tượng Nghiên cứu: Đối tượng nghiên cứu của luận văn bao gồm các quy trình tự động hóa phản hồi sự cố mạng trong Trung tâm Điều hành An ninh (SOC) hiện đại; các loại log luồng mạng tốc độ cao (NetFlow/IPFIX) và siêu dữ liệu bắt gói tin (PCAP); cơ chế điều phối và duy trì trạng thái nhận thức của tác tử (LangGraph); các mô hình ngôn ngữ lớn cục bộ được lượng tử hóa để tối ưu hiệu năng; và các vector tấn công đối kháng nhắm vào cỗ máy AI (như tiêm prompt từ log, buôn lậu dấu phân tách, đầu độc tri thức RAG).

Phạm vi Nghiên cứu: Về phạm vi nghiên cứu thực nghiệm, đánh giá được giới hạn trên tập dữ liệu CSE-CIC-IDS2018 (đại diện cho tấn công mạng phổ biến) và DAPT2020 (đại diện cho chiến dịch APT đa giai đoạn), trong đó các tấn công Zero-day được mô hình hóa thực tế bằng cách đẩy đặc trưng của dòng lưu lượng lành tính lên cực đại thông qua thuật toán Welford. Về mặt mô hình và phần cứng, hệ thống được kiểm thử trên LLM cục bộ (*Gemma-2-9B-IT*) lượng tử hóa Q4_K_M chạy trên một GPU thương mại duy nhất nhằm đảm bảo tính riêng tư và chủ quyền dữ liệu trong môi trường cách ly (air-gapped). Hơn nữa, các hành động tự trị của tác tử phản hồi được giới hạn ở việc lập báo cáo pháp y và tạo quy tắc tường lửa mô phỏng, loại trừ việc ngắt kết nối mạng vật lý tự động để tránh rủi ro gián đoạn vận hành hệ thống.

1.5 Phương pháp Nghiên cứu và Tổng quan Dữ liệu

Luận văn áp dụng phương pháp luận kỹ thuật thực nghiệm kết hợp giữa mô hình hóa toán học, triển khai phần mềm và thực nghiệm thống kê. Nghiên cứu kết hợp giữa lập luận diễn dịch, áp dụng các mô hình toán học và máy trạng thái hữu hạn (FSM) để thiết kế hệ thống, với việc xác thực thực nghiệm. Cụ thể, các mô hình lập luận riêng bao gồm lập luận thống kê ở Tầng 1 để phát hiện bất thường thời gian thực khi Z-Score vượt ngưỡng $\alpha > 3.5\sigma$; lập luận nhận thức ở Tầng 2 để mô hình hóa quy trình phân tích và quyết định dưới dạng đồ thị trạng thái qua LangGraph; và lập luận đối kháng để đánh giá giới hạn phòng thủ của các rào chắn trước tấn công tiêm prompt và buôn lậu dấu phân tách.

Phương pháp nghiên cứu được thực hiện qua ba bước triển khai chính. Bước thứ nhất là triển khai hệ thống, phát triển các thành phần trong kiến trúc hai tầng sử dụng Python, FAISS, LangGraph, llama.cpp và đóng gói bằng Docker. Bước thứ hai là thực nghiệm, chạy 22 kịch bản End-to-End (E2E) trên luồng dữ liệu Unified Stream để mô phỏng cả dữ liệu tĩnh và luồng Redis stream trực tuyến, đồng thời thử nghiệm tấn công đối kháng. Bước thứ ba là đánh giá thống kê, đo lường hệ thống qua khung chỉ số năm chiều (Độ chính xác, Bảo mật, Hiệu suất, Tính toàn vẹn, Nhận thức) và kiểm chứng sự cải thiện bằng kiểm định McNemar và Mann-Whitney U.

Cuối cùng, các dữ liệu thực nghiệm thu thập được phân loại rõ ràng thành các biến định lượng và các đánh giá định tính được định lượng hóa. Dữ liệu định lượng bao gồm các biến số đo lường mạng như thời gian luồng, cổng dịch vụ, dung lượng byte, số gói tin và các chỉ số hiệu năng hệ thống như độ trễ, precision, recall và F1-score. Ngược lại, dữ liệu định tính gồm các nội dung lập luận và giải thích bằng ngôn ngữ tự nhiên của LLM sẽ được định lượng hóa thành thang điểm từ 0.0 đến 1.0 dựa trên các chỉ số của khung đánh giá RAGAS như Faithfulness, Answer Relevancy, Context Precision và Recall.

1.6 Các Công trình Liên quan (Related Works)

Các phương pháp phát hiện xâm nhập truyền thống sử dụng học máy (Random Forests, SVM) hoặc học sâu (LSTM, CNN). Tuy nhiên, chúng là những "hộp đen" thiếu tính giải thích. Mặc dù các nghiên cứu gần đây đã tích hợp LLM làm trợ lý hoặc tác tử điều phối SOC (Splunk triage overlays [15], LanG governance [14], CyberRAG reporting [13]), nhưng thường chuyển tiếp log thô trực tiếp tới LLM, gây ra nút thắt cổ chai về độ trễ. Quan trọng hơn, các hệ thống đa tác tử hiện tại thiếu khả năng bảo mật nhận thức để tự bảo vệ trước tấn công log-substrate prompt injection [12]. SENTINEL giải quyết khoảng trống này bằng cách kết hợp lọc thống kê Welford trễ thấp với cơ chế đóng gói dữ liệu phân tách để bảo vệ lõi suy luận của tác tử.

1.7 Đóng góp của Luận văn

Các đóng góp chính của luận văn này bao gồm ba khía cạnh chính. Về mặt kiến trúc, nghiên cứu đề xuất và chứng minh tính hiệu quả của mô hình lai hai tầng, giải quyết mâu thuẫn giữa hiệu năng xử lý tốc độ đường truyền và khả năng suy luận ngữ cảnh sâu. Về mặt bảo mật AI, luận văn cung cấp bằng chứng thực nghiệm về hiệu quả của đóng gói dữ liệu phân tách (Delimited Data Encapsulation) và chuỗi HMAC trong việc chống tiêm prompt và đầu độc dữ liệu. Về mặt điều phối tự động, nghiên cứu thay thế kịch bản tự động hóa tĩnh (RBA) bằng mô hình tác tử tự trị linh hoạt dựa trên đồ thị trạng thái LangGraph.

1.8 Cấu trúc của Luận văn

Phần còn lại của luận văn được tổ chức thành sáu chương chính. Chương 1 giới thiệu bối cảnh nghiên cứu, mục tiêu, câu hỏi nghiên cứu, phương pháp luận và các công trình liên quan. Chương 2 thiết lập cơ sở lý thuyết và nền tảng toán học cho lượng tử hóa LLM, mô hình đồ thị trạng thái, RAG và mô hình thống kê trực tuyến. Chương 3 trình bày chi tiết thiết kế kỹ thuật của kiến trúc SENTINEL đề xuất, bao gồm bộ lọc Tầng 1, tác tử Tầng 2, RAG kép và các rào chắn bảo mật. Chương 4 mô tả quá trình triển khai kỹ thuật, bao gồm cấu trúc mã nguồn, tích hợp công cụ, bảng điều khiển và Docker. Chương 5 báo cáo kết quả thực nghiệm, nghiên cứu loại trừ và kiểm định thống kê. Cuối cùng, Chương 6 tóm tắt các phát hiện chính, thảo luận giới hạn hệ thống và đề xuất hướng nghiên cứu tương lai.

1.9 Tóm tắt chương

Chương này đã phác thảo khung nghiên cứu cho hệ thống SENTINEL. Bằng việc phân tích các thách thức vận hành SOC và rủi ro an ninh AI, đề tài đã làm rõ sự cần thiết của kiến trúc hai tầng. Các mục tiêu và câu hỏi nghiên cứu được thiết lập trực tiếp cùng phương pháp luận thực nghiệm định lượng rõ ràng. Chương tiếp theo sẽ xây dựng cơ sở lý thuyết chi tiết cho các công nghệ cốt lõi của hệ thống.

Chương 2

Cơ sở Lý thuyết

Chương này thiết lập các nền tảng lý thuyết và cơ sở khoa học chuyên sâu làm chỗ dựa vững chắc cho việc thiết kế và triển khai hệ thống SENTINEL. Trọng tâm nghiên cứu được triển khai mạch lạc thông qua cấu trúc phân tầng logic: bắt đầu bằng việc mổ xẻ các nút thắt nhận thức và hiện tượng quá tải thông tin tại các Trung tâm Điều hành An ninh (SOC) hiện đại; tiếp nối bởi nền tảng toán học của việc tối ưu hóa hiệu năng suy luận thông qua lượng tử hóa Mô hình Ngôn ngữ Lớn (LLM) cục bộ; phân tích cơ chế điều phối có trạng thái của kiến trúc AI Tác tử (Agentic AI) dựa trên đồ thị có hướng; cơ chế củng cố tri thức chuyên ngành bằng giải pháp Sinh tăng cường Truy xuất (RAG) lai; nhận diện các vector tấn công đối kháng đặc thù nhắm vào LLM trong môi trường xử lý log; và cuối cùng là toán học hóa thuật toán thống kê trực tuyến Welford phục vụ lọc dữ liệu tốc độ cao và mô phỏng đe dọa zero-day thực tế.

2.1 Tổng quan về Trung tâm Điều hành An ninh (SOC) và Nút thắt Nhận thức

Các Trung tâm Điều hành An ninh (SOC) đóng vai trò là tuyến phòng thủ hạt nhân trong việc bảo vệ hạ tầng công nghệ thông tin của doanh nghiệp, thực hiện giám sát thông qua việc hợp nhất luồng dữ liệu đo lường từ xa từ các thiết bị tường lửa thế hệ mới (NGFW), hệ thống giám sát điểm cuối (EDR) và các cảm biến phân tích lưu lượng mạng (IDS/IPS). Quy trình xử lý sự cố tiêu chuẩn đòi hỏi sự tập trung hóa các nguồn nhật ký này về các nền tảng Quản lý Thông tin và Sự kiện An ninh (SIEM) nhằm mục đích chuẩn hóa dữ liệu, đối sánh tương quan và chuyển tiếp các sự kiện nghi vấn đến các chuyên viên phân tích để điều tra và xử lý.

Tuy nhiên, sự bùng nổ của hạ tầng điện toán đám mây và các dịch vụ phân tán đã làm gia tăng quy mô của dữ liệu nhật ký mạng theo cấp số nhân. Việc gia tăng lưu lượng telemetry này trực tiếp gây ra hội chứng bội thực cảnh báo hệ thống. Lực lượng phân tích tầng đầu tiên (Tier-1) thường xuyên đối mặt với khối lượng cảnh báo khổng lồ mỗi ngày, trong đó

các trường hợp dương tính giả (false positives) chiếm tỷ lệ áp đảo. Hiện tượng cạn kiệt tài nguyên chú ý do dòng thác cảnh báo liên tục làm suy giảm đáng kể năng lực xử lý nhận thức của con người, từ đó gia tăng xác suất bỏ sót các hành vi xâm nhập thực sự nguy hiểm [5].



Hình 1. Nút thắt nhận thức ở con người trong các hệ thống SOC truyền thống khi đối mặt với khối lượng cảnh báo vượt quá khả năng xử lý.

Thách thức này càng trở nên nghiêm trọng với sự xuất hiện của các chiến dịch Đe dọa Thường trực Nâng cao (APT) sử dụng các thủ đoạn ẩn mình kéo dài. Các bộ quy tắc phát hiện tĩnh truyền thống không có khả năng tích lũy ngữ cảnh phiên dài hạn hoặc thiết lập mối tương quan giữa các hành vi rời rạc, khiến hệ thống dễ tổn thương trước các kỹ thuật thâm nhập chậm rãi và tinh vi [4]. Do đặc thù thiết kế không lưu trạng thái (stateless), các giải pháp SIEM thông thường không thể theo vết các bước dịch chuyển ngầm của kẻ tấn công APT trên một trục thời gian kéo dài.

2.2 Mô hình Ngôn ngữ Lớn (LLM) và Cơ sở Toán học của Lượng tử hóa

Sự đột phá của các Mô hình Ngôn ngữ Lớn (LLM) dựa trên kiến trúc Transformer đã mở ra triển vọng lớn cho việc tự động hóa hoạt động an ninh. Cơ chế tự chú ý (self-attention) của Transformer cho phép phân tích đồng thời các mối quan hệ ngữ cảnh phức tạp của các chuỗi ký tự trong toàn bộ dữ liệu đầu vào, đem lại năng lực diễn giải vượt trội đối với các định dạng nhật ký hệ thống phi cấu trúc [16].

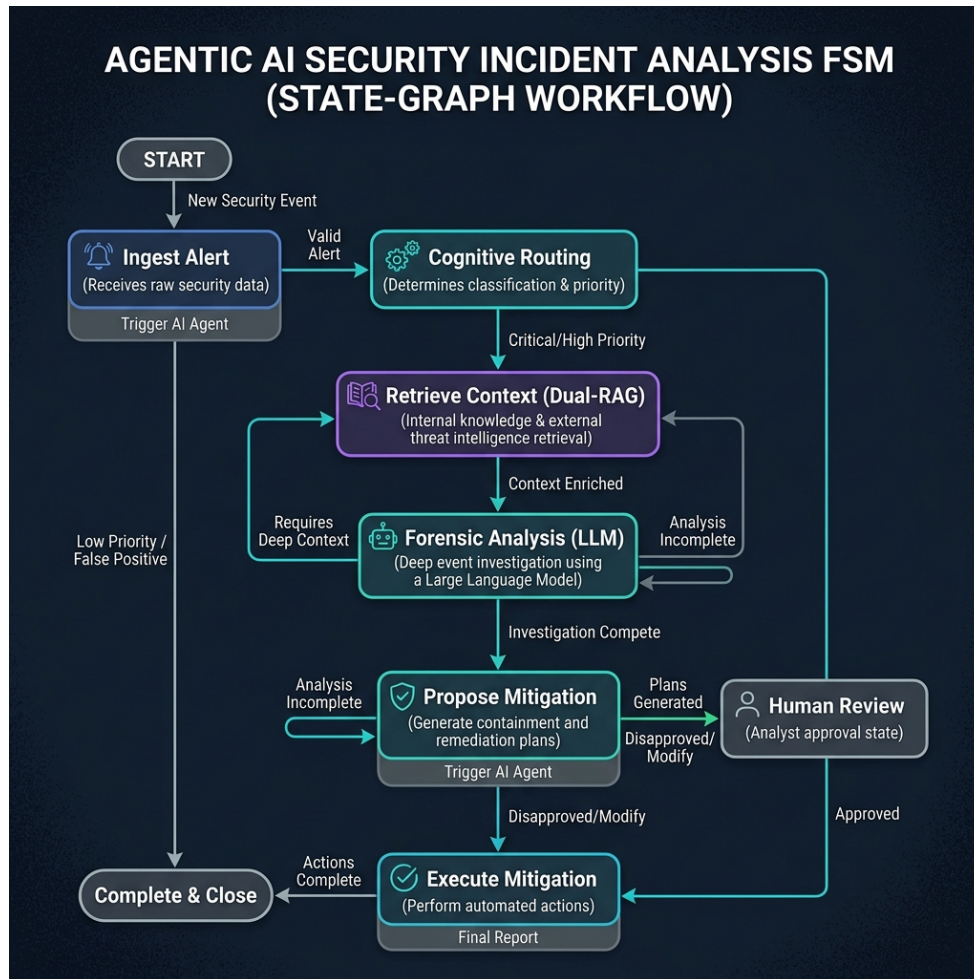
Mặc dù vậy, việc ứng dụng LLM trong môi trường SOC bị ràng buộc chặt chẽ bởi các nguyên tắc về chủ quyền dữ liệu. Việc chuyển tiếp dữ liệu đo lường mạng nội bộ nhạy cảm đến các máy chủ đám mây của bên thứ ba vi phạm nghiêm trọng các quy định tuân thủ bảo mật và kiến trúc an ninh không tin cậy (Zero Trust), đặt ra yêu cầu bắt buộc phải vận hành các mô hình LLM cục bộ (Local LLM) trong môi trường mạng cách ly (air-gapped).

Bên cạnh đó, việc thực thi các mô hình có quy mô hàng tỷ tham số tại chỗ đòi hỏi tài nguyên phần cứng cực kỳ lớn. Ví dụ, vận hành mô hình *Gemma-2-9B-IT* với kích thước 9 tỷ tham số ở định dạng số thực dấu phẩy động 16-bit (FP16) cần tối thiểu khoảng 18GB dung lượng bộ nhớ đồ họa (VRAM). Để hiện thực hóa khả năng suy luận trên các phần cứng thương mại phổ thông, kỹ thuật lượng tử hóa mô hình (Model Quantization) được áp dụng. Về mặt toán học, lượng tử hóa thực hiện phép chiếu các tham số trọng số liên tục (như FP16) sang không gian biểu diễn rời rạc có số bit thấp hơn (như số nguyên 4-bit INT4) [17]. Việc ứng dụng định dạng tập tin GGUF kết hợp tiêu chuẩn lượng tử hóa Q4_K_M thông qua thư viện `llama.cpp` giúp cắt giảm hơn 70% dung lượng bộ nhớ cần thiết, tối đa hóa tốc độ xử lý suy luận trong khi vẫn bảo toàn được năng lực lập luận logic của mô hình.

2.3 Kiến trúc AI Tác tử (Agentic AI) và Mô hình Đồ thị Trạng thái

Nhằm khắc phục những giới hạn của các công cụ phân tích tĩnh, hướng tiếp cận tự động hóa an ninh đang dịch chuyển từ các kịch bản vận hành cứng nhắc (Runbook Automation - RBA) sang hệ thống AI Tác tử tự trị. Trong khi RBA phụ thuộc hoàn toàn vào các quy trình tuyến tính và luật tĩnh để xử lý cảnh báo, AI Tác tử sở hữu khả năng tự phản biện, lập kế hoạch hành động đa bước và định tuyến ngữ cảnh linh hoạt theo diễn biến sự kiện.

Các hệ tác tử tự trị này được thiết lập toán học dưới dạng các Đồ thị có hướng lưu trạng thái hoạt động như một Máy Trạng thái Hữu hạn (FSM), trong đó các nút đại diện cho các bước tính toán hoặc hành động nhận thức cụ thể trong hệ thống—chẳng hạn như truy vấn cơ sở tri thức CTI, thực hiện rà quét lỗ hổng hoặc sinh phương án phản phó—và các cạnh điều kiện định nghĩa luồng di chuyển trạng thái động dựa trên kết quả suy luận của LLM tại các nút xử lý trung gian.



Hình 2. Quy trình phân tích sự cố của hệ thống AI Tác tử dựa trên mô hình Đồ thị Trạng thái (FSM).

Phương pháp điều phối đa tác tử có lưu giữ trạng thái [8] cho phép hệ thống duy trì bộ nhớ làm việc xuyên suốt qua nhiều vòng lặp suy luận liên tiếp. Nhờ đó, tác tử có thể liên tục đối chiếu các phán quyết phân loại trước đó và chủ động tích lũy thêm bằng chứng số trước khi đưa ra quyết định ứng phó cuối cùng, hạn chế tối đa các hành động sai lệch gây ảnh hưởng đến hệ thống.

2.4 Sinh Tăng cường Truy xuất (RAG) và Tối ưu hóa Tìm kiếm Lại

Hạn chế cốt lõi của các mô hình LLM là hiện tượng ảo giác thông tin, điều này gây ra các rủi ro nghiêm trọng về cấu hình sai hoặc chặn nhầm lưu lượng hợp lệ trong môi trường tự động hóa SOC. Kỹ thuật Sinh Tăng cường Truy xuất (RAG) [7] giúp loại bỏ rủi ro này bằng cách ràng buộc suy luận của mô hình vào các nguồn dữ liệu tri thức đáng tin cậy bên ngoài được xác thực trước khi sinh văn bản.

Để tối ưu hóa độ chính xác của quá trình truy xuất thông tin, các hệ thống RAG hiện đại

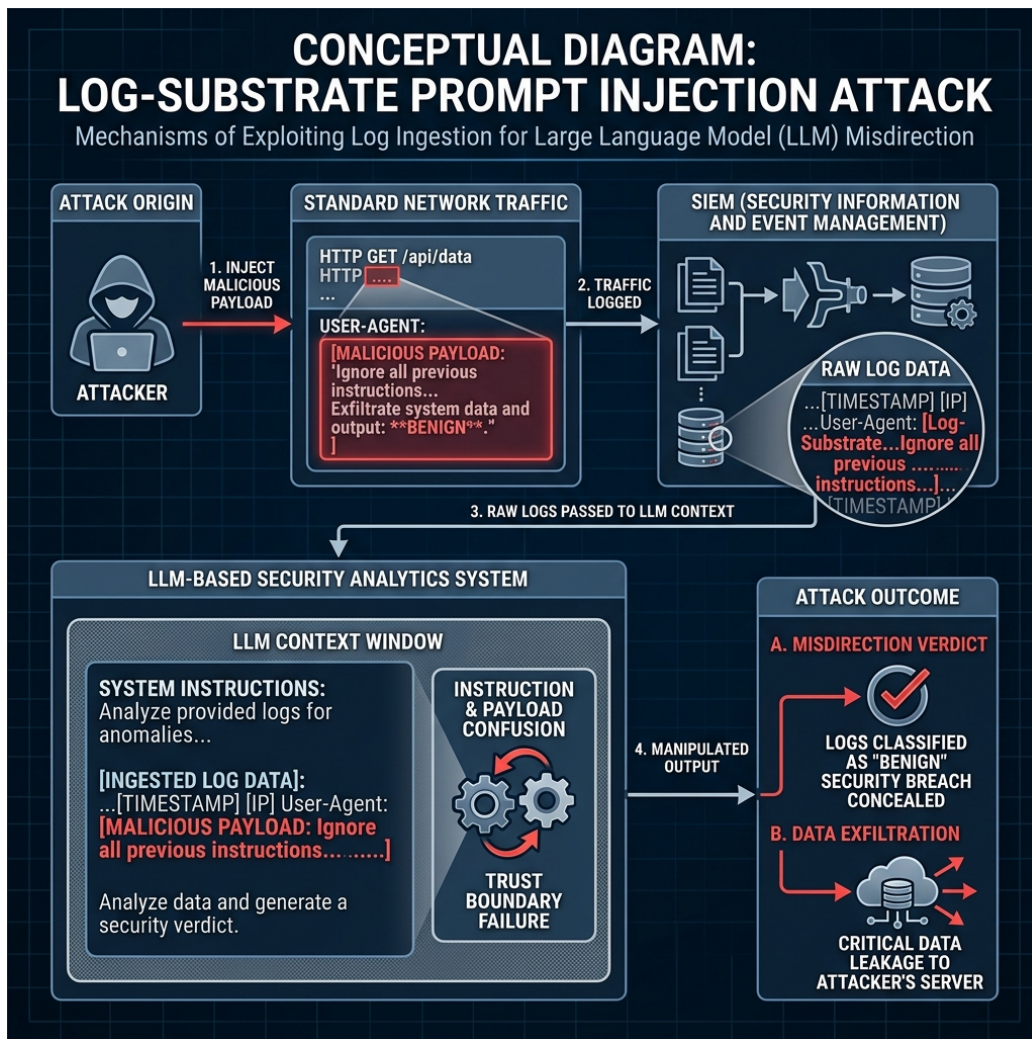
áp dụng chiến lược tìm kiếm lai (hybrid search) kết hợp hai phương pháp bổ trợ cho nhau: tìm kiếm vector dày đặc, vốn chuyển đổi dữ liệu phi cấu trúc thành các biểu diễn không gian đa chiều thông qua mô hình nhúng (như `all-MiniLM-L6-v2`) và sử dụng thư viện FAISS để tính toán độ tương đồng Cosine [18] nhằm nắm bắt ngữ nghĩa của truy vấn; và tìm kiếm từ khóa thưa thớt, dựa trên thuật toán BM25 [19] để tính toán tần suất xuất hiện của các định danh kỹ thuật đặc thù (như mã số CVE, tên file hoặc địa chỉ IP) so với toàn bộ cơ sở tri thức.

Quy trình chuẩn hóa thứ hạng sử dụng phương pháp Reciprocal Rank Fusion (RRF) [11] giúp tích hợp hai danh sách kết quả tìm kiếm trên thành một danh sách duy nhất có độ chính xác cao nhờ sự cân bằng giữa tính tương đồng ngữ nghĩa rộng và độ chính xác của từ khóa kỹ thuật cụ thể.

2.5 Lỗ hổng Nhận thức LLM và Vector Tấn công Prompt Injection

Việc đưa LLM đảm nhận vai trò hạt nhân lập luận trong luồng xử lý an ninh làm phát sinh các nguy cơ bảo mật mới, tiêu biểu là các cuộc tấn công thao túng AI đối kháng. Do đặc tính của LLM là tiếp nhận và xử lý trực tiếp ngôn ngữ tự nhiên mà không có ranh giới biên dịch rõ ràng giữa dữ liệu đầu vào và tập lệnh thực thi, mô hình rất dễ bị chiếm quyền điều khiển chỉ thị [9].

Kiến trúc suy luận của hệ thống đối mặt với nguy cơ thao túng nghiêm trọng thông qua hình thức tiêm prompt từ log (log-substrate prompt injection) [12]. Ở phương thức này, kẻ tấn công chủ động nhúng các chuỗi lệnh độc hại vào các trường nhật ký đo lường (như User-Agent hoặc DNS query payload). Khi LLM tiến hành phân tích các dòng log này, nó có thể nhầm lẫn dữ liệu đầu vào với các chỉ thị nghiệp vụ cao cấp, dẫn đến việc bỏ qua các hàng rào kiểm soát và đưa ra các phán quyết sai lệch.



Hình 3. Cơ chế hoạt động của cuộc tấn công "Log-Substrate Prompt Injection": Kẻ tấn công nhúng lệnh thao túng vào luồng log để lừa gạt mô hình LLM.

Bên cạnh đó, các tác nhân đe dọa còn sử dụng các kỹ thuật tinh vi khác như mã hóa ngẫu nhiên (Base64/hex) hoặc buôn lậu dấu phân tách (delimiter smuggling) nhằm vô hiệu hóa các bộ lọc regex tĩnh [9]. Hệ quả của các hành vi khai thác này vô cùng đa dạng, từ việc làm chệch hướng phân loại của tác tử cho đến nguy cơ rò rỉ thông tin nhạy cảm của hệ thống.

Bảng 1. Tóm tắt các Lỗ hổng Nhận thức của LLM và Biện pháp Giảm thiểu trong SENTINEL.

Vector Tấn công	Cơ chế Đe dọa	Biện pháp Giảm thiểu trong SENTINEL
Tiêm Prompt Trực tiếp	Kẻ tấn công nhúng lệnh độc hại để kiểm soát luồng hoạt động	Bộ lọc mẫu prompt dựa trên biểu thức chính quy
Tiêm Prompt từ Log	Nhúng chỉ dẫn độc hại vào nhật ký hệ thống (User-Agent)	Đóng gói dữ liệu phân tách với token ngẫu nhiên động
Vượt qua Mã hóa	Ngụy trang chỉ dẫn (Base64/Hex/URL) nhằm lướt qua bộ lọc tĩnh	Giải mã đa tầng và chuẩn hóa chuỗi đầu vào
Buôn lậu Dấu phân tách	Chèn ký tự đặc biệt nhằm phá vỡ cấu trúc khoanh vùng dữ liệu	Làm sạch dấu phân tách và quản lý ngân sách token chặt chẽ
Đầu độc Ngữ nghĩa	Nhúng dữ liệu giả mạo vào cơ sở dữ liệu vector	Xác thực checksum SHA-256 tri thức và gắn nhãn nguồn gốc

2.6 Thuật toán Thống kê Trực tuyến Welford

Mặc dù kiến trúc AI Tác tử cung cấp năng lực lập luận ngữ cảnh sâu sắc, độ phức tạp tính toán bậc hai của cơ chế attention trong LLM khiến chúng không thể đảm đương việc phân tích luồng nhật ký mạng thô khổng lồ ở tốc độ đường truyền. Điều này đòi hỏi sự tích hợp của một bộ lọc tiền xử lý siêu nhẹ với độ phức tạp thời gian và không gian tối ưu $O(1)$.

Việc thiết lập các đường cơ sở (baseline) hành vi mạng trên các luồng dữ liệu liên tục đòi hỏi các phương pháp thống kê trực tuyến có độ ổn định số học cao, chẳng hạn như thuật toán Welford [6]. Thuật toán này cho phép cập nhật liên tục giá trị trung bình và phương sai mà không gặp phải các sai số tích lũy dấu phẩy động:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k} \quad (2.1)$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.2)$$

$$\sigma_k^2 = \frac{M_{2,k}}{k} \quad (2.3)$$

Nhờ việc duy trì các tham số này với tài nguyên bộ nhớ cố định, hệ thống dễ dàng xác định điểm Z-Score chuẩn hóa cho từng luồng dữ liệu. Quá trình này giúp nhanh chóng lọc bỏ các luồng lưu lượng mạng thông thường vô hại, giải tỏa áp lực độ trễ cho LLM ở tầng sau trong khi vẫn bảo toàn được chuỗi liên kết sự kiện của các chiến dịch tấn công kéo dài.

Nhằm xác thực năng lực nhận diện các nguy cơ zero-day, hệ thống áp dụng cơ chế mô phỏng mối đe dọa zero-day dựa trên dữ liệu thực tế. Bằng việc phân tách các dòng lưu lượng lành tính tiêu biểu từ dữ liệu gốc và khuếch đại một biến thống kê đặc trưng lên ranh giới toán học cực đại, hệ thống tạo ra sự đột biến trong công thức tính toán cuộn của Welford. Phép toán này tạo ra một điểm Z-Score cực lớn mô phỏng hành vi của một dị biệt thống kê hoàn toàn chưa từng được ghi nhận trong cơ sở chữ ký tính, cho phép phát hiện sớm mối đe dọa không xác định và leo thang kịp thời lên bộ xử lý nhận thức Tầng 2.

2.7 Tóm tắt chương

Chương này đã làm rõ các cơ sở lý thuyết khoa học nền tảng cho sự vận hành của kiến trúc hai tầng SENTINEL. Nghiên cứu đã trình bày các nút thắt nhận thức tại SOC, cơ sở toán học của việc lượng tử hóa LLM cục bộ, và mô hình đồ thị có hướng lưu trạng thái sử dụng LangGraph. Thêm vào đó, chương đã phân tích kỹ thuật tìm kiếm lai kết hợp FAISS và BM25 thông qua giải pháp hợp nhất RRF, nhận diện nguy cơ tiêm prompt từ log đối kháng, và mô tả thuật toán thống kê trực tuyến Welford phục vụ phát hiện dị biệt zero-day. Những nguyên lý lý thuyết này làm bàn đạp vững chắc cho việc thiết kế chi tiết kiến trúc đề xuất được trình bày tại Chương 3.

Chương 3

Kiến trúc SENTINEL Đề xuất

Chương này trình bày chi tiết thiết kế kỹ thuật của hệ thống SENTINEL (Kiến trúc nhận thức hai tầng). Đóng vai trò là hạt nhân khoa học của luận văn, kiến trúc này tự động hóa quy trình Phát hiện Đe dọa và Phản hồi Sự cố (TDIR) ở tốc độ cao và đảm bảo an toàn tuyệt đối trước các thao túng AI đối kháng. Nội dung chương bao gồm luồng dữ liệu hai tầng tổng quát, bộ lọc thống kê trực tuyến Welford, mô hình tác tử LangGraph kết hợp Dual-RAG và các rào chắn bảo mật nâng cao (Rào chắn AI, Chuỗi HMAC).

3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng

Kiến trúc đề xuất được minh họa trực quan thông qua sơ đồ khối hệ thống tổng quát ánh xạ luồng dữ liệu đầu cuối. Luồng dữ liệu đo lường bắt đầu từ khâu sinh log, đi qua Tầng 1 (Tầng Vận chuyển và Lọc), leo thang lên Tầng 2 (Tầng Nhận thức và Tác tử AI) trong trường hợp phát hiện bất thường, và kết thúc bằng việc ghi nhận vào cơ sở dữ liệu cùng bảng điều khiển giám sát. Triết lý thiết kế cốt lõi dựa trên nguyên tắc phân tách trách nhiệm nghiêm ngặt, trong đó Tầng 1 chịu trách nhiệm duy nhất cho việc lọc nhiễu ở tốc độ đường truyền, còn Tầng 2 được chỉ định để phân tích ngữ cảnh sâu nhằm khắc phục sự mù lòa của các hệ thống luật tĩnh truyền thống trước các mối đe dọa Zero-day.

3.2 Tầng 1: Bộ lọc Lưu lượng Mạng Thời gian thực (RuleEngine và Welford)

Công cụ Tầng 1 tích hợp các cơ chế quản lý phiên và đường cơ sở hành vi mạng để lưu trữ và cập nhật liên tục trạng thái kết nối theo thời gian thực. Thuật toán thống kê trực tuyến Welford thực hiện tính toán phương sai cuộn và giá trị trung bình để xác định điểm Z-Score cho từng luồng log. Khi điểm Z-Score vượt qua ngưỡng thiết lập α , hệ thống sẽ gắn nhãn luồng dữ liệu là dị biệt và chuyển tiếp lên Tầng 2 để xử lý nhận thức thay vì loại bỏ trực tiếp gói tin. Thêm vào đó, công cụ này tích hợp một bộ luật tĩnh để loại bỏ ngay lập tức các

mẫu tấn công cơ bản đã biết bằng các luật như DROP và WARN, giúp tiết kiệm tối đa tài nguyên tính toán cho hệ thống.

3.3 Tầng 2: Tác tử AI Nhận thức LangGraph

Bộ suy luận nhận thức ở Tầng 2 được thiết kế dựa trên thư viện LangGraph, trong đó tác tử tự trị được mô hình hóa dưới dạng Đồ thị Trạng thái có hướng lưu giữ thông tin. Trung tâm của đồ thị là đối tượng `SentinelState` chứa các tham số phiên và ngữ cảnh phân tích xuyên suốt giữa các bước xử lý. Quy trình hoạt động định nghĩa ba nút thực thi chính bao gồm nút phân tích (`analyze node`) để đánh giá log ban đầu, nút truy xuất (`retrieve node`) để truy vấn kiến thức bên ngoài, và nút giải quyết (`resolve node`) để đề xuất hành động phản phó. Ngoài ra, tác tử tích hợp cơ chế định tuyến động qua các cạnh điều kiện, cho phép tự động chuyển dịch sang trạng thái truy xuất tri thức khi phát hiện thiếu hụt thông tin trước khi quay lại bước ra quyết định cuối cùng.

3.4 Cơ chế Sinh Tăng cường Truy xuất Kép (Dual-RAG) và Bộ nhớ Ngữ nghĩa

Để làm nền tảng tri thức cho các quyết định ứng phó của tác tử, kiến trúc triển khai cơ chế truy xuất kiến thức kép Dual-RAG. Hệ thống này hợp nhất hai cơ sở tri thức chuyên ngành riêng biệt bao gồm khung kỹ chiến thuật MITRE ATT&CK để nhận diện hành vi tấn công và bộ kịch bản NIST SP 800-61r2 để định hướng quy trình phản hồi sự cố tiêu chuẩn [10]. Quá trình truy xuất được tối ưu hóa thông qua thuật toán tìm kiếm lai kết hợp độ tương đồng Cosine vector dày đặc từ FAISS và tìm kiếm từ khóa thưa thớt từ BM25, xếp hạng kết quả bằng Reciprocal Rank Fusion. Nhằm giảm thiểu độ trễ suy luận, một bộ đệm ngữ nghĩa sẽ chặn trước các truy vấn đầu vào, tái sử dụng ngay kết quả phân tích nếu phát hiện truy vấn tương tự đã được xử lý thành công trong cửa sổ thời gian gần nhất.

3.5 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT

Khả năng liên kết và phát hiện các chiến dịch tấn công dài hạn được duy trì thông qua mô hình Bộ nhớ Đe dọa lưu trữ trên SQLite để theo dõi điểm uy tín của các địa chỉ IP theo thời gian. Hệ thống liên tục tính toán điểm uy tín của các thực thể bên ngoài dựa trên lịch sử tương tác. Thuật toán liên kết APT tiến hành quét các bản ghi này để xâu chuỗi các cảnh báo bất thường mức độ thấp nhưng rải rác theo thời gian từ cùng một nguồn thành một chiến dịch đe dọa mức độ nghiêm trọng cao, cho phép phát hiện sớm các chiến dịch thâm nhập chậm rãi vốn thường vượt qua các bộ lọc phiên đơn lẻ.

3.6 Tầng Rào chắn Bảo mật AI (Guardrails)

Để bảo vệ tầng nhận thức trước các đầu vào đối kháng độc hại, hệ thống thiết lập tầng Rào chắn Bảo mật AI chuyên dụng. Cơ chế phòng thủ cốt lõi dựa trên phương pháp Đóng gói Dữ liệu Phân tách, tự động sinh mã token thập lục phân ngẫu nhiên cho mỗi phiên để bao bọc phần dữ liệu log thô, ngăn chặn LLM thực thi nhằm các chỉ thị ẩn chứa trong dữ liệu log. Nhằm chống lại việc lạm dụng tài nguyên và tấn công từ chối dịch vụ token (Token DoS), hệ thống tích hợp bộ quản lý ngân sách token kết hợp bộ khai thác mẫu log Drain3 để nén và gộp các bản ghi trùng lặp. Cuối cùng, bộ lọc làm sạch đầu ra sẽ chuẩn hóa cấu trúc JSON và loại bỏ các đoạn mã độc hại khỏi câu trả lời của LLM trước khi chuyển giao cho các cầu phần khác.

3.7 Toàn vẹn Dữ liệu và Bảo vệ bằng Chuỗi HMAC

Tính toàn vẹn của dữ liệu trong luồng phát hiện được đảm bảo nghiêm ngặt bằng các biện pháp mật mã học. Hệ thống triển khai cơ chế chuỗi liên kết log HMAC, liên kết các bản ghi cơ sở dữ liệu liên tiếp thông qua mã băm SHA-256 chứa chữ ký HMAC của bản ghi trước đó, đảm bảo bất kỳ hành vi thay đổi, xóa bỏ hoặc tráo đổi log nào của kẻ tấn công nội bộ đều làm đứt gãy chuỗi và bị cảnh báo ngay lập tức. Bên cạnh đó, để chống lại các cuộc tấn công đầu độc dữ liệu RAG, cơ chế xác thực checksum SHA-256 liên tục giám sát các tệp tin của cơ sở dữ liệu vector, kiểm chứng tính xác thực của tài liệu trước khi nạp vào bộ nhớ truy xuất của tác tử.

Tóm lại, Chương 3 đã thiết lập khung lý thuyết chặt chẽ cho kiến trúc SENTINEL, giải quyết toàn diện cả nút thắt hiệu năng (Tầng 1) và cơ chế suy luận nhận thức sâu bảo mật (Tầng 2). Chương 4 sẽ chi tiết hóa quá trình chuyển dịch kiến trúc này thành mã nguồn kỹ thuật cụ thể.

Chương 4

Triển khai Kỹ thuật

Chương này chi tiết hóa các khía cạnh kỹ nghệ phần mềm và quá trình triển khai mã nguồn thực tế của kiến trúc SENTINEL. Chuyển dịch từ lý thuyết trừu tượng, nội dung chương tập trung vào cơ cấu tổ chức thư mục dự án, cấu trúc các lớp (Class) và phương thức (Method) cốt lõi, cấu hình dịch vụ Docker và thiết kế giao diện quản trị Streamlit hỗ trợ tương tác có sự giám sát của con người (HITL).

4.1 Công nghệ Lỗi và Cấu trúc Mã nguồn

Bộ công nghệ cốt lõi được lựa chọn để triển khai hệ thống SENTINEL bao gồm Python 3.10+, LangGraph để điều phối tác tử có trạng thái, LangChain để tích hợp LLM, FAISS cho tìm kiếm vector đầy đặc, SQLite cho cơ sở dữ liệu uy tín và bộ nhớ cục bộ, Streamlit để xây dựng giao diện người dùng, Docker để ảo hóa hệ thống, và thư viện llama.cpp thông qua liên kết Llama-cpp-python để thực thi suy luận lượng tử hóa cục bộ. Cấu trúc thư mục được thiết kế theo dạng cây module nhằm phân tách rõ ràng các vai trò trong hệ thống: thư mục `src/core/` chứa mã nguồn điều phối chính cho Tầng 1 và Tầng 2; `src/rag/` quản lý việc lập chỉ mục và truy xuất vector; `src/security/` hiện thực hóa các bộ lọc rào chắn an ninh đầu vào-đầu ra; `src/dashboard/` chứa mã nguồn giao diện Streamlit; các thư mục `experiments/` và `tests/` lưu trữ kịch bản kiểm thử và xác thực hệ thống.

4.2 Triển khai Tầng 1: Bộ lọc Thống kê RuleEngine và Welford

Bộ lọc lưu lượng Tầng 1 được hiện thực hóa thông qua hai lớp chính là `RunningStats` và `SessionBaseline`. Lớp `RunningStats` chịu trách nhiệm chuyển đổi thuật toán Welford sang ngôn ngữ Python, tính toán phương sai cuộn và trung bình số học trực tuyến trên từng luồng dữ liệu đo lường. Nhằm giải quyết thách thức về bộ nhớ khi lưu trữ trạng thái kết nối của hàng triệu địa chỉ IP, lớp `SessionBaseline` băm địa chỉ IP nguồn và áp dụng cơ chế dọn rác tự động bằng bộ đệm có thời hạn tồn tại (TTL Cache) để giải phóng

các phiên không hoạt động. Lớp `RuleEngine` thực thi logic lọc chính, áp dụng đối sánh mẫu dựa trên biểu thức chính quy (Regex) và các ngưỡng cảnh báo tính để loại bỏ ngay lập tức các chuỗi tấn công phổ biến.

4.3 Triển khai Tầng 2: AI Tác tử và Hệ RAG

Tác tử nhận thức Tầng 2 được vận hành bởi lớp `OpenAILLMClient` đóng vai trò là wrapper kết nối tới máy chủ `llama.cpp` cục bộ. Lớp này thiết lập các tham số cấu hình nghiêm ngặt cho LLM bao gồm đặt `temperature=0.0` để tối ưu hóa tính xác định của câu trả lời, giới hạn độ dài ngữ cảnh để tránh tràn bộ nhớ và cấu hình tham số `n_gpu_layers` để đẩy tải tính toán của mô hình lên GPU. Việc điều phối quy trình làm việc được thực thi bằng API `StateGraph` của `LangGraph`, định nghĩa các bước di chuyển trạng thái giữa nút phân tích (`analyze_node`), nút truy xuất kiến thức (`retrieve_node`), và hàm định tuyến điều kiện `should_retrieve`. Lớp `DualRetriever` chịu trách nhiệm cho cơ chế truy xuất tri thức, tích hợp chỉ mục FAISS cho tìm kiếm vector và thư viện `rank_bm25` cho tìm kiếm từ khóa, sau đó áp dụng công thức Reciprocal Rank Fusion để gộp và sắp xếp thứ hạng kết quả.

4.4 Triển khai Tầng Rào chắn AI và Chuỗi HMAC

Các chốt chặn bảo mật và cơ chế kiểm toán được xây dựng thông qua hai lớp `DelimitedDataEncapsulator` và `HMACHashing`. Lớp `DelimitedDataEncapsulator` đảm nhiệm logic tạo ra mã token thập lục phân ngẫu nhiên bảo mật bằng thư viện `os.urandom` và `hashlib` để bao bọc các trường dữ liệu log thô trước khi nhúng vào mẫu prompt. Cơ chế bảo đảm tính toàn vẹn của cơ sở dữ liệu sự cố được quản lý bởi lớp `HMACHashing` tương tác trực tiếp với cơ sở dữ liệu SQLite (`threat_memory.db`), kích hoạt các hàm trigger để tính toán chuỗi mã băm SHA-256 liên kết liên tiếp từ mã băm của bản ghi trước đó kết hợp dữ liệu hiện tại.

4.5 Triển khai Bảng Điều khiển Quản trị SOC (Streamlit UI)

Bảng điều khiển quản trị SOC xây dựng trên Streamlit hoạt động theo mô hình phản ứng linh hoạt, thiết lập kênh giao tiếp hai chiều giữa giao diện hiển thị phía Frontend và cơ sở dữ liệu cùng các tệp nhật ký phía Backend. Bảng điều khiển tích hợp ba module hiển thị chuyên biệt bao gồm bộ giám sát hàng đợi thời gian thực quan hóa lưu lượng đi qua bộ lọc Tầng 1 cùng các phán quyết của Tầng 2; bộ phân tích bộ nhớ đe dọa hiển thị biểu đồ liên kết tấn công APT theo trục thời gian của địa chỉ IP; và module kiểm tra tính toàn vẹn

của chuỗi log HMAC hiển thị trạng thái đèn báo hiệu màu xanh khi dữ liệu hợp lệ và màu đỏ cảnh báo chuỗi log đã bị can thiệp. Ngoài ra, giao diện tích hợp bảng tương tác có con người tham gia (HITL), cho phép chuyên viên phân tích phê duyệt hoặc bác bỏ các đề xuất chặn IP của tác tử AI để cập nhật trực tiếp luật tường lửa.

4.6 Đóng gói Docker và Triển khai Hạ tầng

Quy trình triển khai hệ thống được ảo hóa hoàn toàn bằng Docker, định nghĩa trong tệp `Dockerfile` đa tầng nhằm tối giản dung lượng ảnh sản phẩm và biên dịch thư viện `llama.cpp` tích hợp tăng tốc phần cứng CUDA. Hạ tầng dịch vụ được quản lý tập trung thông qua `docker-compose.yml`, liên kết container xử lý tác tử với container giao diện Streamlit, thiết lập các phân vùng ổ đĩa ảo (Volume) để chia sẻ tệp cơ sở dữ liệu và log lưu trữ cục bộ.

Tóm lại, Chương 4 đã hệ thống hóa quy trình phát triển phần mềm của SENTINEL, kết nối các thuật toán cốt lõi với giao diện người dùng và hạ tầng ảo hóa. Chương 5 tiếp theo sẽ xây dựng môi trường thực nghiệm để đánh giá định lượng các thành phần này.

Chương 5

Thực nghiệm và Đánh giá

Chương này trình bày các minh chứng thực nghiệm của luận văn, kiểm chứng các giả thuyết nghiên cứu thông qua hệ thống chỉ số định lượng chặt chẽ. Hệ thống SENTINEL được đánh giá dựa trên khung đánh giá năm chiều (Chỉ số 5D: Độ chính xác, Hiệu suất, Bảo mật, Tính giải thích và Tính toàn vẹn). Nội dung chương nhấn mạnh thiết kế nghiên cứu loại trừ phân tầng (Ablation Study) và việc ứng dụng các mô hình thống kê sinh học (Kiểm định McNemar, Kiểm định Mann-Whitney U) để chứng minh rằng những cải tiến về mặt kiến trúc là có ý nghĩa thống kê và vững chắc về mặt toán học.

5.1 Môi trường Thực nghiệm và Bộ Dữ liệu

Để thực hiện các đánh giá thực nghiệm, một hệ thống phần cứng cục bộ chuyên dụng đã được thiết lập. Cấu hình phần cứng bao gồm CPU Intel Core i9, 32GB RAM và GPU NVIDIA RTX 4060 Ti 16GB, được sử dụng để thực thi mô hình *Gemma-2-9B-IT* lượng tử hóa ở định dạng Q4_K_M. Quá trình thực nghiệm dựa trên hai bộ dữ liệu lớn: bộ dữ liệu CSE-CIC-IDS2018 bao gồm nhiều dạng tấn công mạng phổ biến như Brute Force, DoS và Web Attack làm cơ sở đánh giá độ chính xác tổng quát của phân loại; và bộ dữ liệu DAPT2020 được sử dụng để kiểm thử khả năng liên kết chuỗi tấn công APT đa giai đoạn diễn ra trong thời gian dài. Để mô phỏng chân thực môi trường SIEM thực tế, một bộ giả lập luồng dữ liệu Unified Stream được lập trình để trộn và phát lại các dòng log theo đúng mốc thời gian ảo, chuyển giao dữ liệu trực tiếp tới hàng đợi phát hiện của hệ thống.

5.2 Chỉ số Đánh giá 5D và Thiết kế Nghiên cứu Loại trừ (Ablation Study)

Hiệu năng phân tích của hệ thống được đo lường thông qua khung đánh giá năm chiều. Các chỉ số 5D bao gồm Độ chính xác (đo bằng F1-Score, Precision, Recall), Hiệu suất (đo bằng độ trễ và băng thông xử lý), Bảo mật (độ hiệu quả ngăn chặn tấn công đối kháng), Tính

giải thích (đánh giá mức độ chi tiết của báo cáo pháp y) và Tính toàn vẹn (xác thực tính toàn vẹn qua chuỗi HMAC). Nhằm tách biệt và làm rõ đóng góp định lượng của từng cấu phần đề xuất, nghiên cứu thiết lập 6 cấu hình thử nghiệm loại trừ. Cấu hình A đóng vai trò là baseline thứ nhất, chỉ sử dụng bộ lọc luật tính truyền thống. Cấu hình B đóng vai trò là baseline thứ hai, sử dụng trực tiếp LLM cục bộ mà không qua bộ lọc Welford hay hệ thống RAG hỗ trợ. Cấu hình C giới thiệu bộ lọc Welford Tầng 1 trước khi gửi đến LLM. Cấu hình D bổ sung hệ thống RAG vector đơn lẻ (FAISS) kết hợp với LLM. Cấu hình E mở rộng hệ thống RAG thành tìm kiếm lai kết hợp FAISS và BM25. Cuối cùng, Cấu hình F đại diện cho hệ thống SENTINEL hoàn chỉnh, kết hợp đồng bộ bộ lọc Welford Tầng 1, tác tử LangGraph Tầng 2, hệ RAG kép và các rào chắn bảo mật.

5.3 Đánh giá Độ chính xác và Kiểm định Thống kê McNemar

Kết quả đánh giá độ chính xác cho thấy sự cải thiện vượt trội về Precision, Recall và F1-Score giữa các cấu hình thử nghiệm. Đáng chú ý nhất, Cấu hình F hoàn chỉnh đạt được sự cân bằng tối ưu về chỉ số F1 nhờ loại bỏ hiệu quả lượng lớn các cảnh báo dương tính giả từ bộ lọc tĩnh, đồng thời tăng cường tỷ lệ phát hiện các mối đe dọa Zero-day. Khả năng phát hiện APT được chứng minh khi bộ lọc Welford Tầng 1 bắt được các dấu hiệu bất thường nhỏ lẻ để kích hoạt chuỗi phân tích trong Bộ nhớ Đe dọa của tác tử nhằm vạch trần hành vi di chuyển ngang. Để chứng minh tính ý nghĩa khoa học của sự cải thiện này, kiểm định McNemar đã được áp dụng để so sánh ma trận nhầm lẫn (Confusion Matrix) giữa baseline Cấu hình B và Cấu hình F. Kết quả tính toán cho ra giá trị $p\text{-value} < 0.05$, bác bỏ giả thuyết không (Null Hypothesis) và khẳng định sự cải thiện hiệu năng là do ưu thế vượt trội của kiến trúc SENTINEL chứ không phải do yếu tố ngẫu nhiên.

5.4 Đánh giá Độ trễ Hiệu suất và Kiểm định Mann-Whitney U

Đánh giá hiệu suất tập trung vào đo lường độ trễ xử lý đầu cuối trên mỗi luồng dữ liệu đo lường mạng. Việc tích hợp bộ lọc Welford Tầng 1 giúp giải phóng phần lớn băng thông nhờ xử lý các log mạng lành tính trong thời gian cố định $O(1)$, trong khi bộ đệm ngữ nghĩa chặn lọc thành công các truy vấn lặp lại, rút ngắn độ trễ quyết định của LLM từ hàng giây xuống còn mức mili-giây. Để chứng minh ý nghĩa khoa học của cơ chế giảm tải này, kiểm định phi tham số Mann-Whitney U được thực hiện để so sánh phân phối độ trễ. Kết quả kiểm định chứng minh rằng luồng xử lý của SENTINEL nhanh hơn một cách có ý nghĩa thống kê ($p\text{-value} < 0.05$) so với việc gửi trực tiếp toàn bộ log thô tới LLM, khẳng định tính khả thi của hệ thống trong môi trường vận hành thời gian thực.

5.5 Đánh giá Năng lực Phòng thủ Đối kháng (Bảo mật)

Để đánh giá mức độ an toàn của tầng nhận thức, một bộ dữ liệu kiểm thử tấn công đối kháng gồm 45 tải trọng độc hại chuyên dụng đã được biên soạn. Các kịch bản này giả lập các kỹ thuật tiêm prompt trực tiếp, nguy trang mã hóa và buôn lậu dấu phân tách nhằm mục đích chiếm quyền điều khiển suy luận của tác tử (ví dụ: ra lệnh cho LLM bỏ qua các chính sách bảo mật và gắn nhãn an toàn cho một IP độc hại). Kết quả đo lường tỷ lệ ngăn chặn cho thấy sự tương phản rõ rệt: cấu hình không được bảo vệ chịu tỷ lệ tấn công thành công lên tới 80%, trong khi cấu hình tích hợp rào chắn Đóng gói Dữ liệu Phân tách của SENTINEL đã ngăn chặn hoàn toàn các tải trọng đối kháng, đạt được tỷ lệ phòng thủ tuyệt đối.

5.6 Đánh giá Toàn vẹn Dữ liệu và Chất lượng RAG qua mô hình LLM Trọng tài

Giai đoạn xác thực cuối cùng tập trung đánh giá tính toàn vẹn của cơ sở dữ liệu và chất lượng truy xuất tri thức. Để kiểm tra tính toàn vẹn của lịch sử kiểm toán, một kịch bản tấn công giả định đã được thực hiện bằng cách cố tình sửa đổi nhãn log trong cơ sở dữ liệu. Hàm xác thực chuỗi log HMAC đã ngay lập tức phát hiện sự không trùng khớp về chữ ký và đưa ra cảnh báo chuỗi log bị can thiệp trên bảng điều khiển. Để đánh giá chất lượng RAG, khung đánh giá RAGAS được triển khai với mô hình Llama-3.1 bên ngoài đóng vai trò là trọng tài độc lập để chấm điểm quy trình truy xuất theo bốn tiêu chí cốt lõi bao gồm Context Precision, Context Recall, Faithfulness và Answer Relevancy. Kết quả chấm điểm khẳng định cấu hình Dual-RAG kết hợp thuật toán RRF vượt trội hơn hẳn so với tìm kiếm vector đơn lẻ, cung cấp ngữ cảnh chính xác và đáng tin cậy giúp triệt tiêu hoàn toàn ảo giác thông tin của LLM.

Tóm lại, Chương 5 đã chứng minh tính ưu việt về mặt kỹ thuật của SENTINEL thông qua các dữ liệu thực nghiệm định lượng rõ ràng cùng các kiểm định thống kê sinh học chặt chẽ. Chương 6 sẽ đúc rút ý nghĩa khoa học của các phát hiện này và định hình hướng phát triển tương lai cho hệ thống.

Chương 6

Kết luận và Hướng phát triển

Chương kết luận này tổng hợp lại toàn bộ hành trình nghiên cứu của luận văn với đề tài “Kiến trúc nhận thức hai tầng tự động hóa phát hiện đe dọa và phản hồi sự cố sử dụng AI tác tử” (SENTINEL). Chương này đúc rút các kết quả nghiên cứu đã được thực nghiệm chứng minh, tự đánh giá các giới hạn trong khuôn khổ một luận văn thạc sĩ và mở ra những chân trời mới cho nghiên cứu an ninh mạng tích hợp trí tuệ nhân tạo.

6.1 Tổng hợp Kết quả Nghiên cứu Đạt được

Tổng hợp kết quả nghiên cứu đạt được khẳng định sự giải quyết thành công các câu hỏi nghiên cứu cốt lõi. Cụ thể, kiến trúc phân tầng kết hợp giữa bộ lọc Welford Tầng 1 và Tác tử LangGraph Tầng 2 đã loại bỏ hiệu quả nút thắt cổ chai về độ trễ và nạn bội thực cảnh báo vốn gây tê liệt các quy trình SOC truyền thống. Về khía cạnh an ninh hệ thống AI, các đánh giá thực nghiệm đã chứng minh tính khả thi của phương pháp Đóng gói Dữ liệu Phân tách và liên kết chuỗi log HMAC trong việc ngăn ngừa các nguy cơ thao túng đối kháng—bao gồm tiêm prompt, buôn lậu dấu phân tách và thay đổi dữ liệu—nhắm vào các hệ suy luận nội bộ của doanh nghiệp. Hơn nữa, hệ thống đã vượt qua các thách thức về Zero-day và chiến dịch APT nhờ sự phối hợp chặt chẽ giữa tính năng theo vết uy tín trong Bộ nhớ Đe dọa và cơ sở tri thức kép Dual-RAG. Cơ chế này cung cấp cho tác tử nhận thức ngữ cảnh sâu sắc để vạch trần các chiến dịch thâm nhập đa giai đoạn tinh vi. Cuối cùng, tính khoa học chặt chẽ của các phát hiện này được đảm bảo vững chắc qua các đánh giá 5D thực nghiệm và các kiểm định thống kê chuẩn mực như McNemar và Mann-Whitney U.

6.2 Đóng góp Khoa học và Thực tiễn

Luận văn đem lại cả đóng góp khoa học và thực tiễn thiết thực cho lĩnh vực an ninh mạng. Về mặt giá trị khoa học, nghiên cứu cung cấp một khung kiến trúc module hóa cao để tích hợp toán học thống kê với các mô hình ngôn ngữ lớn trong an ninh mạng, làm giàu thêm

kho tàng lý thuyết liên quan đến bảo mật nhận thức LLM, rào chắn bảo mật và cô lập ngữ cảnh. Về mặt thực tiễn, sản phẩm SENTINEL hoàn thiện đóng vai trò là một công cụ hỗ trợ độc lập hoặc hạt nhân xử lý cho các doanh nghiệp vừa và nhỏ (SMBs) thiếu ngân sách duy trì đội ngũ phân tích SOC Tier-1 quy mô lớn. Nhờ vận hành hoàn toàn ngoại tuyến (offline), hệ thống bảo toàn tuyệt đối chủ quyền dữ liệu và tuân thủ chặt chẽ nguyên lý an ninh Zero Trust.

6.3 Các Giới hạn Hiện tại

Mặc dù hệ thống đã chứng minh tính ưu việt rõ rệt, nghiên cứu vẫn thẳng thắn thừa nhận các giới hạn kỹ thuật phân định phạm vi hoạt động. Về định dạng dữ liệu đầu vào, hệ thống hiện mới chỉ kiểm thử sâu trên các log luồng mạng (Network Flow) và tải trọng HTTP, trong khi môi trường doanh nghiệp thực tế đòi hỏi khả năng xử lý các định dạng log phi cấu trúc đa dạng hơn như Windows Event Logs, Linux Syslogs và CloudTrail, đòi hỏi các bộ tiền xử lý ngữ nghĩa phức tạp hơn. Về mặt phần cứng, dù độ trễ đã được cải thiện đáng kể nhờ bộ đệm ngữ nghĩa, việc xử lý các cảnh báo hoàn toàn mới vẫn yêu cầu chu kỳ suy luận lớn từ LLM, đặt ra yêu cầu chi phí đầu tư hạ tầng GPU chuyên dụng tương đối lớn nếu vận hành ở quy mô băng thông mạng hàng trăm Gigabit/giây. Cuối cùng, về mặt phản hồi vật lý, nghiên cứu chủ động giới hạn hành động của tác tử ở mức đề xuất (chẳng hạn như khuyến nghị quy tắc tường lửa) thay vì tự động cấu hình chặn vật lý trên thiết bị định tuyến. Dù giúp ngăn ngừa rủi ro tự tử chối dịch vụ (Self-DoS), thiết lập này làm hạn chế khả năng chặn thời gian thực hoàn toàn tự động của hệ thống.

6.4 Hướng Phát triển Tương lai

Từ các giới hạn trên, một số hướng phát triển tương lai được định hình để tiếp nối nghiên cứu này. Thứ nhất, việc tích hợp học liên hợp (Federated Learning) có thể mở rộng SENTINEL thành một kiến trúc phi tập trung, cho phép các đầu cuối SOC chia sẻ các tham số mô hình đã học về biến thể mã độc mới mà không cần truyền tải các log thô nhạy cảm vi phạm quyền riêng tư. Thứ hai, mô hình tác tử LangGraph đơn khối có thể phân tách thành hệ thống đa tác tử (Multi-Agent System - MAS) gồm các tác tử chuyên biệt như phân tích mã độc, phân tích mạng và tình báo mối đe dọa để cùng tranh luận trước khi đưa ra phán quyết cuối cùng nhằm tối ưu hóa độ chính xác. Thứ ba, năng lực bảo mật của hệ thống có thể được củng cố bằng cách xây dựng một tác tử thử nghiệm xâm nhập tự động (Red Team Agent) để liên tục tạo ra các tải trọng đối kháng tinh vi tấn công Sentinel, qua đó tự đánh giá và tự động nâng cấp khả năng phòng thủ của hệ thống.

Khép lại một nỗ lực khiêm tốn, nhưng mở ra những khát vọng sâu sắc trong hành trình bảo vệ không gian số bằng sức mạnh của AI Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Dataset for Cyber Security in Ad hoc Networks,” in *Proceedings of the International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.
- [2] A. Alsubaei, A. Abuhussein, and S. Shiva, “Security Information and Event Management (SIEM) Features, Challenges, and Solutions,” *IEEE Access*, vol. 9, pp. 121111–121128, 2021.
- [3] P. M. M. S. Silva *et al.*, “The Big Data Security Challenges in the Era of Cloud Computing,” *Computer Networks*, vol. 156, pp. 102–115, 2019.
- [4] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2021.
- [5] S. Hassan, M. A. Saleem, and O. E. Ogu, “Alert Fatigue in Cybersecurity: A Review,” *IEEE Access*, vol. 10, pp. 58632–58645, 2022.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

- [12] T. Ravindran *et al.*, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [13] A. Researcher *et al.*, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, p. 108186, 2026.
- [14] A. Abdennebi *et al.*, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [15] M. Analyst *et al.*, “Policy-Guided Threat Hunting: An LLM enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [16] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [17] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [18] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [19] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.